

УТВЕРЖДАЮ

Директор _____

Щеглов Т.М. . _____
(Должность, ФИО руководителя)

« 24 » января 2026 г.

МОДЕЛЬ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

информационной системы персональных данных «Бухгалтерия»

наименование системы и (или) систем

ОГЛАВЛЕНИЕ

Список сокращений и обозначений	3
Термины и определения	4
1. общие положения	12
1.1 Назначение и область действия документа.....	12
1.2 Нормативные правовые акты и методические документы.....	12
1.3 Сведения об обладателе информации, операторе и заказчике систем и сетей	12
1.4 Подразделения и должностные лица, ответственные за обеспечение безопасности систем и сетей	13
2. Общая характеристика и техническое описание объектов защиты.....	15
3. Возможные негативные последствия от реализации угроз безопасности информации.....	24
4. Возможные объекты воздействия угроз безопасности информации	26
5. Источники угроз безопасности информации.....	29
6. Способы реализации угроз безопасности информации	33
6.1. Актуальные способы реализации угроз безопасности информации	33
7. Актуальные угрозы безопасности информации	40
Вывод об актуальности угроз	45

СПИСОК СОКРАЩЕНИЙ И ОБОЗНАЧЕНИЙ

АВС – антивирусные средства

АРМ – автоматизированное рабочее место

АС – автоматизированная система

АСЗИ – автоматизированная система в защищенном исполнении

ГИС – государственная информационная система

ИСПДн – информационная система персональных данных

ЛВС – локальная вычислительная сеть

МЭ – межсетевой экран

ОС – операционная система

ПДн – персональные данные

ПМВ – программно-математическое воздействие

ПО – программное обеспечение

ПЭМИН – побочные электромагнитные излучения и наводки

САЗ – система анализа защищенности

СЗИ – средства защиты информации

СЗПДн – система (подсистема) защиты персональных данных

СКЗИ – средства криптографической защиты информации

СОВ – система обнаружения вторжений

УБПДн – угрозы безопасности персональных данных

ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

Автоматизированная система (АС) – система, состоящая из персонала и комплекса средств автоматизации его деятельности, реализующая информационную технологию выполнения установленных функций.

Автоматизированная система в защищенном исполнении (АСЗИ) – автоматизированная система, реализующая информационную технологию выполнения установленных функций в соответствии с требованиями стандартов и (или) иных нормативных документов по защите информации.

Атака – целенаправленные действия нарушителя с использованием технических и (или) программных средств с целью нарушения заданных характеристик безопасности защищаемой криптосредством информации или с целью создания условий для этого.

Аутентификация отправителя данных – подтверждение того, что отправитель полученных данных соответствует заявленному.

Безопасность – состояние защищенности жизненно важных интересов личности, общества и государства от внутренних и внешних угроз.

Безопасность информации – состояние защищённости информации, характеризующееся способностью пользователей, технических средств и информационных технологий обеспечить конфиденциальность, целостность и доступность информации.

Блокирование информации – временное прекращение сбора, систематизации, накопления, использования, распространения, информации, в том числе её передачи.

Вирус (компьютерный, программный) – исполняемый программный код или интерпретируемый набор инструкций, обладающий свойствами несанкционированного распространения и самовоспроизведения. Созданные дубликаты компьютерного вируса не всегда совпадают с оригиналом, но сохраняют способность к дальнейшему распространению и самовоспроизведению.

Вредоносная программа – программа, предназначенная для осуществления несанкционированного доступа и (или) воздействия на персональные данные или ресурсы информационной системы персональных данных.

Вспомогательные технические средства и системы – технические средства и системы, не предназначенные для передачи, обработки и хранения персональных данных, устанавливаемые совместно с техническими средствами и системами, предназначенными для обработки персональных данных или в помещениях, в которых установлены информационные системы персональных данных.

Доступ к информации – возможность получения информации и её использования.

Документированные (декларированные) возможности ПО (ТС) – функциональные возможности ПО (ТС), описанные в документации на ПО (ТС).

Доступ в операционную среду компьютера (информационной системы персональных данных) – получение возможности запуска на выполнение штатных команд, функций, процедур операционной системы (уничтожения, копирования, перемещения и т.п.), исполняемых файлов прикладных программ.

Защищаемая информация – информация, являющаяся предметом собственности и подлежащая защите в соответствии с требованиями правовых документов или требованиями, устанавливаемыми собственником информации.

Идентификация – присвоение субъектам и объектам доступа идентификатора и (или) сравнение предъявляемого идентификатора с перечнем присвоенных идентификаторов.

Инсталляция – установка программного продукта на компьютер. Инсталляция обычно выполняется под управлением инсталлятора – программы, которая приводит состав и структуру устанавливаемого программного изделия в соответствии с конфигурацией компьютера, а также настраивает программные параметры согласно типу имеющейся операционной системы, классам решаемых задач и режимам работы. Таким образом, инсталляция делает программный продукт пригодным для использования в данной вычислительной системе и готовым решать определенный класс задач в определенном режиме работы.

Информационная система – совокупность содержащейся в базах данных информации и обеспечивающих ее обработку информационных технологий и технических средств.

Информационная система персональных данных – совокупность содержащихся в базах данных персональных данных и обеспечивающих их обработку информационных технологий и технических средств.

Информационно-телекоммуникационная сеть – технологическая система, предназначенная для передачи по линиям связи информации, доступ к которой осуществляется с использованием средств вычислительной техники.

Информационно-телекоммуникационная сеть общего пользования – информационно-телекоммуникационная сеть, которая открыта для использования всеми физическими и юридическими лицами и в услугах которой этим лицам не может быть отказано.

Информационные технологии - процессы, методы поиска, сбора, хранения, обработки, предоставления, распространения информации и способы осуществления таких процессов и методов.

Информация – сведения (сообщения, данные) независимо от формы их представления.

Использование персональных данных - действия (операции) с персональными данными, совершаемые оператором в целях принятия решений или совершения иных действий, порождающих юридические последствия в отношении субъекта персональных данных или других лиц либо иным образом затрагивающих права и свободы субъекта персональных данных или других лиц.

Канал атаки – среда переноса от субъекта к объекту атаки (а, возможно, и от объекта к субъекту атаки) действий, осуществляемых при проведении атаки.

Конфиденциальность информации – обязательное для выполнения лицом, получившим доступ к определенной информации, требование не передавать такую информацию третьим лицам без согласия ее обладателя.

Конфиденциальность персональных данных – обязательное для соблюдения оператором или иным получившим доступ к персональным данным лицом требование не допускать их распространение без согласия субъекта персональных данных или наличия иного законного основания.

Контролируемая зона — это пространство (территория, здание, часть здания, помещение), в котором исключено неконтролируемое пребывание посторонних лиц, а также транспортных, технических и иных материальных средств.

Криптографически опасная информация (КОИ) – информация о состояниях криптосредства, знание которой нарушителем позволит ему строить алгоритмы определения ключевой информации (или ее части) или алгоритмы бесключевого чтения.

Криптосредство – шифровальное (криптографическое) средство, предназначенное для защиты информации, не содержащей сведений, составляющих государственную тайну. В частности, к криптосредствам относятся средства криптографической защиты информации (СКЗИ) - шифровальные (криптографические) средства защиты информации с ограниченным доступом, не содержащей сведений, составляющих государственную тайну.

Межсетевой экран – локальное (однокомпонентное) или функционально-распределенное программное (программно-аппаратное) средство (комплекс), реализующее контроль за информацией, поступающей в информационную систему персональных данных и (или) выходящей из информационной системы.

Модель нарушителя – предположения о возможностях нарушителя, которые он может использовать для разработки и проведения атак, а также об ограничениях на эти возможности.

Модель угроз – перечень возможных угроз информации.

Нарушитель (субъект атаки) – лицо (или иницилируемый им процесс), проводящее (проводящий) атаку.

Нарушитель безопасности персональных данных – физическое лицо, случайно или преднамеренно совершающее действия, следствием которых является нарушение безопасности персональных данных при их обработке техническими средствами в информационных системах персональных данных.

Негативные функциональные возможности – документированные и недокументированные возможности программных и аппаратных компонентов криптосредства и среды функционирования криптосредства, позволяющие:

модифицировать или исказить алгоритм работы криптосредств в процессе их использования;

модифицировать или исказить информационные или управляющие потоки и процессы, связанные с функционированием криптосредства;

получать доступ нарушителям к хранящимся в открытом виде ключевой, идентификационной и (или) аутентифицирующей информации, а также к защищаемой информации.

Недекларированные возможности – функциональные возможности средств вычислительной техники, не описанные или не соответствующие описанному в документации, при использовании которых возможно нарушение конфиденциальности, доступности или целостности обрабатываемой информации.

Несанкционированный доступ (несанкционированные действия) – доступ к информации или действия с информацией, нарушающие правила разграничения доступа с использованием штатных средств, предоставляемых информационными системами персональных данных.

Носитель информации – физическое лицо или материальный объект, в том числе физическое поле, в котором информация находит свое отражение в виде символов, образов, сигналов, технических решений и процессов, количественных характеристик физических величин.

Обезличивание персональных данных - действия, в результате которых становится невозможным без использования дополнительной информации определить принадлежность персональных данных конкретному субъекту персональных данных.

Обладатель информации – лицо, самостоятельно создавшее информацию либо получившее на основании закона или договора право разрешать или ограничивать доступ к информации, определяемой по каким-либо признакам.

Обработка персональных данных – любое действие (операция) или совокупность действий (операций), совершаемых с использованием средств автоматизации или без использования таких средств с персональными данными, включая сбор, запись, систематизацию, накопление, хранение, уточнение (обновление, изменение), извлечение, использование, передачу (распространение, предоставление, доступ), обезличивание, блокирование, удаление, уничтожение персональных данных.

Общедоступные персональные данные - персональные данные, доступ неограниченного круга лиц к которым предоставлен с согласия субъекта персональных данных или на которые в соответствии с федеральными законами не распространяется требование соблюдения конфиденциальности.

Объект информатизации – совокупность информационных ресурсов, средств и систем обработки информации, используемых в соответствии с заданной информационной технологией, средств обеспечения объекта информатизации, помещений или объектов (зданий, сооружений, технических средств), в которых они установлены, или помещения и объекты, предназначенные для ведения конфиденциальных переговоров.

Оператор – государственный орган, муниципальный орган, юридическое или физическое лицо, самостоятельно или совместно с другими лицами организующие и (или) осуществляющие обработку персональных данных, а также определяющие цели обработки персональных данных, состав персональных данных, подлежащих обработке, действия (операции), совершаемые с персональными данными.

Опубликованные возможности ПО или ТС – возможности, сведения о которых содержатся в общедоступных открытых источниках (технические и любые другие материалы разработчика ПО или ТС, монографии, публикации в СМИ, материалы конференций и других форумов, информация из сети Internet и т.д.).

Перехват (информации) - неправомерное получение информации с использованием технического средства, осуществляющего обнаружение, прием и обработку информативных сигналов.

Персональные данные – любая информация, относящаяся к прямо или косвенно определенному или определяемому лицу (субъекту персональных данных).

Побочные электромагнитные излучения и наводки – электромагнитные излучения технических средств обработки защищаемой информации, возникающие как побочное явление и вызванные электрическими сигналами, действующими в их

электрических и магнитных цепях, а также электромагнитные наводки этих сигналов на токопроводящие линии, конструкции и цепи питания.

Пользователь информационной системы персональных данных – лицо, участвующее в функционировании информационной системы персональных данных или использующее результаты ее функционирования.

Пользователь – лицо, участвующее в эксплуатации криптосредства или использующее результаты его функционирования.

Правила разграничения доступа – совокупность правил, регламентирующих права доступа субъектов доступа к объектам доступа.

Программная закладка – код программы, преднамеренно внесенный в программу с целью осуществить утечку, изменить, блокировать, уничтожить информацию или уничтожить и модифицировать программное обеспечение информационной системы персональных данных и(или) блокировать аппаратные средства.

Программное (программно-математическое) воздействие - несанкционированное воздействие на ресурсы автоматизированной информационной системы, осуществляемое с использованием вредоносных программ.

Распространение персональных данных - действия, направленные на раскрытие персональных данных неопределенному кругу лиц.

Ресурс информационной системы - именованный элемент системного, прикладного или аппаратного обеспечения функционирования информационной системы.

Средства криптографической защиты информации - средства шифрования, средства имитозащиты, средства кодирования, средства электронной цифровой подписи, средства изготовления ключевых документов (независимо от вида носителя ключевой информации), ключевые документы (независимо от вида носителя ключевой информации).

Средства шифрования - аппаратные, программные и аппаратно-программные средства, системы и комплексы, реализующие алгоритмы криптографического преобразования информации и предназначенные для защиты информации при передаче по каналам связи и (или) для защиты информации от несанкционированного доступа при ее обработке и хранении.

Средства электронной подписи - аппаратные, программные и аппаратно-программные средства, обеспечивающие на основе криптографических преобразований реализацию хотя бы одной из следующих функций: создание электронной подписи с использованием закрытого ключа электронной подписи, подтверждение с использованием открытого ключа электронной подписи подлинности электронной цифровой подписи, создание закрытых и открытых ключей электронной цифровой подписи.

Средства вычислительной техники - совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем.

Субъект доступа (субъект) – лицо или процесс, действия которого регламентируются правилами разграничения доступа.

Технические средства информационной системы – технические средства, осуществляющие обработку информации (средства вычислительной техники, информационно-вычислительные комплексы и сети, средства и системы передачи, приема и обработки информации (средства и системы звукозаписи, звукоусиления, звуковоспроизведения, переговорные и телевизионные устройства, средства изготовления, тиражирования документов и другие технические средства обработки речевой, графической, видео- и буквенно-цифровой информации), программные средства (операционные системы, системы управления базами данных и т.п.), средства защиты информации).

Технический канал утечки информации – совокупность носителя информации (средства обработки), физической среды распространения информативного сигнала и средств, которыми добывается защищаемая информация.

Угроза безопасности – совокупность условий и факторов, создающих опасность жизненно важным интересам личности, общества и государства.

Угроза безопасности объекта – возможное нарушение характеристики безопасности объекта.

Угрозы безопасности информации – совокупность условий и факторов, создающих опасность несанкционированного, в том числе случайного, доступа к персональным данным, результатом которого может стать уничтожение, изменение, блокирование, копирование, распространение информации, а также иных несанкционированных действий при её обработке в информационной системе.

Успешная атака – атака, достигшая своей цели.

Утечка (защищаемой) информации по техническим каналам – неконтролируемое распространение информации от носителя защищаемой информации через физическую среду до технического средства, осуществляющего перехват информации.

Уполномоченное оператором лицо – лицо, которому на основании договора оператор поручает обработку персональных данных.

Учетность – свойство, обеспечивающее однозначное отслеживание собственных действий любого логического объекта.

Уязвимость - некая слабость, которую можно использовать для нарушения системы или содержащейся в ней информации.

Целостность информации - способность средства вычислительной техники или информационной системы обеспечивать неизменность информации в условиях случайного и/или преднамеренного искажения (разрушения).

1. ОБЩИЕ ПОЛОЖЕНИЯ

1.1 Назначение и область действия документа

Настоящая Модель угроз разработана в соответствии с ФЗ-152 «О персональных данных», приказом ФСТЭК № 21 и методическими указаниями ФСТЭК России по оценке угроз.

Целью документа является определение перечня актуальных угроз для ИСПДн «Бухгалтерия», оценка вероятности их реализации и подготовка предложений по обеспечению информационной безопасности.

Сфера действия: Модель охватывает все компоненты ИСПДн «Бухгалтерия» – от программно-технических комплексов и баз данных до действий пользователей и процедур обработки персональных данных.

1.2 Нормативные правовые акты и методические документы

При разработке Модели угроз использованы следующие документы:

1. Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных».
2. Федеральный закон от 27 июля 2006 года № 149-ФЗ «Об информации, информационных технологиях и о защите информации».
3. Постановление Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».
4. Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных...».
5. Методический документ. Методика оценки угроз безопасности информации (утвержден ФСТЭК России 5 февраля 2021 года).
6. ГОСТ Р 57580.1–2017 «Безопасность финансовых операций».
7. Рекомендации Банка России по защите информации.
8. Банк данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru).

1.3 Сведения об обладателе информации, операторе и заказчике систем и сетей

Статус обладателя информации, которая проходит обработку в информационной системе персональных данных «Бухгалтерия», закреплен за организацией (юридическим лицом), инициировавшей обработку сведений о своих сотрудниках и прочих субъектах персональных данных.

Функции оператора рассматриваемой системы выполняет указанное юридическое лицо, которое в частном порядке организует и реализует процессы обработки данных в целях обеспечения своей уставной деятельности. Данная деятельность осуществляется в строгом соответствии с положениями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

В роли заказчика разработки данной модели угроз выступает руководство (администрация) организации. В сферу ответственности заказчика входит контроль за соблюдением нормативных правовых актов Российской Федерации, регламентирующих защиту информации и безопасность персональных данных в корпоративных системах.

1.4 Подразделения и должностные лица, ответственные за обеспечение безопасности систем и сетей

Распределение полномочий и ответственности за обеспечение защиты информации в ИСПДн «Бухгалтерия» установлено в следующем порядке:

1. Общее руководство. Полномочия по общему управлению и стратегической координации мер, направленных на защиту информации, закреплены за единоличным исполнительным органом – Руководителем организации (Генеральным директором / Директором).

2. Организационно-методическое обеспечение. Обязанности по непосредственному планированию и реализации комплекса защитных мероприятий возложены на Отдел информационной безопасности (или иное профильное подразделение). В компетенцию данного подразделения входит формирование и актуализация организационно-распорядительного базиса, а также осуществление регулярных процедур внутреннего контроля.

3. Ответственное должностное лицо. Назначение ответственного за обеспечение безопасности персональных данных и контроль функционирования системы защиты ПДн осуществляется из числа руководящего состава (Начальник отдела информационной безопасности или иное уполномоченное лицо).

4. Техническое сопровождение и администрирование. Практическое исполнение технических мер защиты возлагается на системных администраторов и администраторов безопасности ИТ-подразделения. Их зона ответственности включает эксплуатацию сертифицированных средств защиты информации (СЗИ), конфигурирование политик разграничения доступа, управление учетными записями и проведение мониторинга (аудита) событий безопасности.

5. Эксплуатационная ответственность. Ответственность за неукоснительное соблюдение установленного регламента безопасности при работе в системе несут руководители структурных подразделений, задействованных в процессах ИСПДн «Бухгалтерия», а также штатные сотрудники (конечные пользователи), имеющие санкционированный доступ к системе.

6. Надзор и аудит. Надзорные функции за соблюдением требований действующего законодательства РФ в области обработки и защиты персональных данных возложены на Службу внутреннего контроля (или специализированную комиссию/подразделение).

2. ОБЩАЯ ХАРАКТЕРИСТИКА И ТЕХНИЧЕСКОЕ ОПИСАНИЕ ОБЪЕКТОВ ЗАЩИТЫ

2.1. Наименование системы и её границы

Настоящая Модель угроз разработана для **Информационной системы персональных данных «Бухгалтерия»** (далее – ИСПДн «Бухгалтерия», Система). Система представляет собой совокупность программно-аппаратных средств, объединённых в локальную вычислительную сеть (ЛВС) бухгалтерии, и включает серверную часть, автоматизированные рабочие места (АРМ) сотрудников бухгалтерии, сетевое и периферийное оборудование, а также каналы связи. **Границами оценки угроз** являются все компоненты, непосредственно участвующие в обработке, хранении и передаче защищаемой информации в пределах кабинета бухгалтерии (контролируемая зона) и внешние сетевые интерфейсы, через которые осуществляется взаимодействие с сетью Интернет и смежными системами.

2.2. Класс защищенности, категория значимости, уровень защищенности ПДн

- **Уровень защищенности персональных данных:** 3-й уровень (УЗ-3) – установлен в соответствии с требованиями Постановления Правительства РФ от 01.11.2012 № 1119, исходя из обработки иных категорий ПДн (не специальных, не биометрических) при количестве субъектов менее 100 000 сотрудников и актуальности угроз 3-го типа.
- **Класс защищенности (по приказу ФСТЭК №17):** не устанавливается (система не является государственной информационной системой).
- **Категория значимости объекта КИИ:** не является значимым объектом критической информационной инфраструктуры (ФЗ № 187-ФЗ).

2.3. Правовой базис функционирования

Эксплуатация Системы осуществляется в соответствии со следующими нормативными правовыми актами:

- Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных»;
- Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации»;
- Постановление Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;

- Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных...»;
- Приказ ФСТЭК России от 11.02.2013 № 17 «Об утверждении Требований о защите информации, не составляющей государственную тайну...»;
- Трудовой кодекс РФ (в части обработки персональных данных сотрудников).

2.4. Назначение, задачи, состав обрабатываемой информации и правовой режим

Назначение: Автоматизация процессов бухгалтерского, налогового и кадрового учёта, а также взаимодействие с банковскими и государственными информационными системами.

Основные задачи (функции):

- Учёт хозяйственных операций и формирование бухгалтерской отчётности.
- Расчёт заработной платы, отпускных, больничных, налогов и страховых взносов.
- Формирование и отправка платёжных поручений через систему «Клиент-Банк».
- Подготовка и сдача регламентированной отчётности в ФНС, СФР, Росстат.
- Ведение кадрового учёта (приём, перевод, увольнение сотрудников, табельный учёт).
- Хранение архивных данных бухгалтерских и кадровых документов.

Состав обрабатываемой информации и правовой режим:

- *Персональные данные сотрудников* (иные категории): фамилия, имя, отчество; дата и место рождения; паспортные данные; адрес регистрации и проживания; ИНН; СНИЛС; должность; сведения о заработной плате и банковских реквизитах.
Правовой режим: конфиденциальная информация, подлежащая защите в соответствии с ФЗ-152.
- *Финансово-экономическая информация:* бухгалтерские проводки, платёжные реквизиты организации и контрагентов, данные о финансовых результатах.
Правовой режим: коммерческая тайна, информация ограниченного доступа.
- *Налоговая и отчётная информация:* налоговые декларации, расчётные ведомости, отчёты в государственные фонды.
Правовой режим: информация, содержащая ПДн и коммерческие данные, подлежащая защите.

2.5. Основные процессы, для обеспечения которых функционирует система

ИСПДн «Бухгалтерия» обеспечивает выполнение следующих критически важных бизнес-процессов:

1. **Кадровый учёт и сбор персональных данных** – первичный ввод и актуализация личных сведений сотрудников.
2. **Расчёт заработной платы и обязательных отчислений** – автоматизированные вычисления на основе данных кадрового учёта и табельного времени.
3. **Формирование платёжных документов и взаимодействие с банками** – подготовка реестров и платёжных поручений, обмен данными с системой «Клиент-Банк».
4. **Подготовка и сдача налоговой и статистической отчётности** – формирование отчётов и их передача по защищённым каналам в контролирующие органы.
5. **Хранение и архивирование** – долговременное сохранение электронных документов и баз данных, а также уничтожение ПДн по истечении сроков хранения.

2.6. Состав и архитектура системы, интерфейсы и взаимосвязи

Система построена по архитектуре «клиент-сервер» в рамках выделенного сегмента ЛВС организации. Все компоненты размещены в контролируемой зоне – кабинете бухгалтерии.

2.6.1. Перечень основных компонентов

В таблице 1 приведён состав технических средств и программного обеспечения Системы.

Таблица 1 – Компоненты ИСПДн «Бухгалтерия»

Компонент	Тип / Модель	Программное обеспечение / Функция
Сервер приложений	Физический сервер (напр. Dell PowerEdge T150)	ОС Windows Server 2022, платформа «1С:Предприятие 8.3» (серверная часть)
Сервер баз данных	Физический сервер (напр. Dell PowerEdge R450)	ОС Windows Server 2022, СУБД Microsoft SQL Server 2022 / PostgreSQL
АРМ бухгалтеров (2-3 шт.)	Персональные компьютеры (Acer Nitro / аналоги)	ОС Windows 10/11 Pro, клиентская часть 1С, клиент-банк, MS Office, антивирус
АРМ администратора безопасности	Персональный компьютер	ОС Windows 10/11 Pro, средства администрирования и мониторинга
Маршрутизатор / МСЭ	Cisco 2800 Series / MikroTik	ОС маршрутизатора, функции межсетевого экрана, NAT, VPN-сервер
Коммутатор локальной сети	Cisco 2960TT (16 портов)	–

Периферийное оборудование	МФУ (принтер/сканер) HP LaserJet / Canon	Сетевые протоколы печати и сканирования (SMB, IPP)
Источник бесперебойного питания	ИБП	—

2.6.2. Схема архитектуры и взаимодействия

Топология сети – «звезда» с единой точкой выхода в Интернет.

Основные связи:

- АРМ бухгалтеров и администратора подключены к коммутатору, через который осуществляется доступ к серверу приложений 1С и серверу БД по протоколам TCP/IP (порты 1540–1541, 1433/5432).
- Сервер приложений взаимодействует с сервером БД по внутренней сети (выделенный VLAN или физическое соединение).
- Маршрутизатор обеспечивает доступ в сеть Интернет для серверов и АРМ (для обновлений ПО, работы с клиент-банком и сдачи отчётности). На маршрутизаторе настроены правила фильтрации (МСЭ), разрешающие только необходимые исходящие соединения и запрещающие входящие из Интернета, кроме установленных (например, для VPN-подключений).
- МФУ подключено к коммутатору и доступно всем АРМ по протоколам сетевой печати.
- Схема физического размещения оборудования и граница контролируемой зоны приведены на рисунке (не показан, но текстовое описание дано в п. 2.6.3).

2.6.3. Физическое размещение и контролируемая зона

Всё оборудование ИСПДн располагается в изолированном кабинете бухгалтерии, доступ в который ограничен сотрудниками бухгалтерии и ИТ-персоналом. Помещение оборудовано запираемой дверью (механический замок / СКУД). Граница контролируемой зоны проходит по капитальным стенам кабинета. В помещении установлен сейф для хранения бумажных носителей ПДн. Резервные копии баз данных хранятся на внешнем жёстком диске внутри того же помещения.

2.6.4. Внутренние и внешние интерфейсы

В таблице 2 определены основные интерфейсы объектов воздействия.

Таблица 2 – Интерфейсы доступа к компонентам Системы

Объект	Уровень	Тип интерфейса	Описание
Сервер БД	Системный / Прикладной	Логический (SQL-порт 1433/5432), Сетевой (Ethernet)	Доступ к базам данных ПДн через СУБД.

Сервер приложений 1С	Прикладной	Логический (порты 1540, 1541, веб-клиент HTTP/HTTPS)	Обработка запросов от клиентских приложений 1С.
АРМ бухгалтеров	Аппаратный / Системный	Физический (USB-порты, сетевой порт), Логический (RDP, SMB)	Ввод и обработка ПДн, доступ к сетевым ресурсам.
Маршрутизатор	Сетевой	Физический (WAN/LAN-порты), Логический (Web-интерфейс, SSH)	Внешний выход в Интернет, управление правилами фильтрации.
МФУ	Сетевой	Физический (Ethernet), Логический (LPD, IPP, SMB, Web-интерфейс)	Печать документов, сканирование в сетевые папки.
Каналы связи (Интернет)	Сетевой	Логический (TCP/IP, HTTPS, SMTP)	Обмен данными с внешними системами (банки, ФНС, СФР).

2.7. Группы пользователей и их полномочия

В Системе определены две основные группы пользователей (Таблица 3). Разграничение доступа к данным внутри прикладного ПО (1С) частичное: существуют роли, однако на практике бухгалтеры обладают избыточными правами на чтение и изменение большей части данных.

Таблица 3 – Группы пользователей и типы доступа

Группа пользователей	Уровень полномочий	Тип доступа	Разрешенные действия
Администратор безопасности	Привилегированный	Локальный и удалённый (RDP, SSH)	Установка и настройка ПО, администрирование ОС и СУБД, управление учётными записями, резервное копирование, мониторинг событий безопасности.
Операторы ИСПДн (бухгалтеры)	Непривилегированный (в ОС), но с широкими правами в 1С	Локальный (клиент 1С), сетевой доступ к файловым ресурсам	Ввод, изменение и просмотр ПДн сотрудников, формирование отчётности, работа с клиент-банком,

			печать и сканирование документов. Доступ к конфигурации и администрированию системы отсутствует.
--	--	--	--

2.7.1. Матрица доступа на прикладном уровне (1С:Предприятие)

В ходе анализа архитектуры ИСПДн «Бухгалтерия» установлено, что штатная ролевая модель в используемой конфигурации «1С:Предприятие» настроена некорректно: для группы «Операторы» (рядовые бухгалтеры) используется типовый профиль с избыточным набором полномочий. Отсутствует жесткое разделение обязанностей (Segregation of Duties), что формирует предпосылки для реализации внутренних угроз безопасности.

В таблице 2.4 представлена расширенная матрица доступа к критичным объектам 1С, демонстрирующая текущее (фактическое) распределение прав и выявляющая зоны избыточных полномочий.

Обозначения прав доступа:

- **Ч** – Чтение (просмотр)
- **З** – Запись (добавление, изменение)
- **У** – Удаление (пометка на удаление)
- **П** – Проведение (для документов) / Использование (для обработок)
- **Э** – Экспорт (сохранение в файл, вывод на печать списков)

Таблица 2.4 – Матрица доступа пользователей в прикладном ПО (1С) и анализ избыточности

Ключевой объект в БД 1С	Администратор (Главный бухгалтер / ИТ)	Оператор (Рядовой бухгалтер)	Анализ текущего состояния (Выявление избыточных прав)	Связанная актуальная угроза
Справочник «Сотрудники» (и связанные регистры с ПДн)	Ч, З, У, Э	Ч, З, Э	Критичная избыточность. Рядовой бухгалтер имеет право не только просматривать карточки коллег, но и формировать массовые отчеты (списки) со всеми ПДн и беспрепятственно	УБИ.012 (Несанкционированное копирование ПДн)

			сохранять их (экспортировать) в форматы Excel/PDF на свой АРМ.	
Справочники «Контрагенты» и «Банковские счета»	Ч, З, У	Ч, З	Избыточность. Бухгалтер, отвечающий, например, только за расчет зарплаты, имеет техническую возможность редактировать расчетные счета сторонних организаций.	УБИ.123 (Модификация финансовой информации)
Документ «Платежное поручение» и «Зарплатная ведомость»	Ч, З, У, П	Ч, З, П	Избыточность. Нарушен принцип «двух ключей» (maker-checker). Рядовой сотрудник может единолично создать платежное поручение с подменными реквизитами и провести его в базе для последующей выгрузки в Клиент-Банк.	УБИ.123 (Модификация финансовой информации)
Интерактивное открытие внешних отчетов и обработок	Разрешено	Разрешено	Критичная избыточность. Право «Использование внешних отчетов и обработок» у операторов позволяет запустить произвольный код (скрипт) внутри среды 1С для массовой выгрузки базы, минуя стандартные интерфейсы, или запустить вредоносный макрос.	УБИ.012 (Копирование ПДн), УБИ.043 (Внедрение ВПО)
Журнал регистрации	Полный доступ (Ч, З, очистка)	Нет доступа	Уязвимость администрирования. Администратор	УБИ.216 (Удаление журналов аудита)

1С (аудит событий)			имеет возможность бесследно удалять или модифицировать записи о своих действиях в системе (например, скрыть факт изменения реквизитов).	
--------------------	--	--	---	--

Вывод по результатам анализа матрицы доступа:

Анализ ролевой модели в 1С:Предприятие подтверждает наличие серьезных уязвимостей организационно-технического характера. Права доступа рядовых пользователей (бухгалтеров) не ограничены принципом минимальной необходимости.

Наличие у операторов прав на свободный экспорт списков ПДн, изменение любых платежных реквизитов и использование внешних обработок формирует прямой вектор (способ реализации СП.18.2) для осуществления внутреннего мошенничества, кражи данных (УБИ.012) и хищения денежных средств (УБИ.123). Данные факты обосновывают высокий уровень опасности внутреннего нарушителя (Н1) и требуют обязательного внедрения мер защиты класса «Управление доступом» (УД) при проектировании СЗИ.

2.8. Внешние интерфейсы и взаимодействия

Система имеет **подключение к сетям общего пользования (Интернет)** через маршрутизатор. Основные внешние взаимодействия:

- **Система «Клиент-Банк»** – передача платёжных поручений и получение выписок по защищённому каналу (HTTPS).
- **Сдача электронной отчётности** – отправка налоговых деклараций и отчётов в ФНС, СФР через специализированного оператора связи (протокол HTTPS).
- **Обновление программного обеспечения** – загрузка обновлений 1С, антивирусных баз, системных патчей с официальных сайтов.
- **Электронная почта** – для служебной переписки (при необходимости через корпоративный почтовый сервер, но в рамках данной ИСПДн может использоваться почтовый клиент на АРМ бухгалтеров).

Физические интерфейсы на АРМ (USB) позволяют подключать съёмные носители, что создаёт риски несанкционированного копирования информации.

2.9. Информация о функционировании на базе ЦОД или облачной инфраструктуры

ИСПДн «Бухгалтерия» функционирует **локально, на собственных серверных мощностях организации**. Использование услуг центров обработки данных (ЦОД) или облачных сервисов (IaaS, SaaS) не осуществляется. Все технические средства обработки ПДн физически размещены на территории РФ в пределах контролируемой зоны оператора. Ответственность за обеспечение защиты информации полностью возложена на оператора – юридическое лицо.

3. ВОЗМОЖНЫЕ НЕГАТИВНЫЕ ПОСЛЕДСТВИЯ ОТ РЕАЛИЗАЦИИ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

Реализация угроз безопасности информации в ИСПДн «Бухгалтерия» может привести к нарушению критических бизнес-процессов организации, связанных с обработкой персональных данных, ведением бухгалтерского учёта и финансовыми операциями. На основе анализа архитектуры системы, состава обрабатываемой информации и правового режима определены два основных вида риска (ущерба), актуальных для оператора и субъектов ПДн.

Таблица 3.1 – Виды рисков и соответствующие им негативные последствия

№	Вид риска (ущерба)	Типовые негативные последствия (применительно к ИСПДн «Бухгалтерия»)
У1	Ущерб физическому лицу (субъекту ПДн – сотруднику)	1. Нарушение конфиденциальности персональных данных (утечка ФИО, паспорта, ИНН, СНИЛС, зарплаты, сведений о здоровье).
У2	Ущерб юридическому лицу (оператору – организации)	1. Нарушение законодательства РФ (Федеральный закон № 152-ФЗ, Трудовой кодекс) – административная и гражданско-правовая ответственность, крупные штрафы. 2. Финансовый ущерб: – прямое хищение денежных средств через подмену платёжных реквизитов в системе «Клиент-Банк»; – необходимость незапланированных затрат на выплату штрафов, компенсаций, восстановление системы. 3. Репутационный ущерб – потеря доверия сотрудников, контрагентов, контролирующих органов. 4. Нарушение штатного режима функционирования – простой ИСПДн, срыв сроков расчёта зарплаты,

		сдачи отчётности, проведения платежей. 5. Принятие неправильных управленческих и финансовых решений на основе искажённых данных (нарушение целостности). 6. Дискредитация работников бухгалтерии – компрометация учётных записей для совершения подложных операций от их имени.
--	--	--

4. ВОЗМОЖНЫЕ ОБЪЕКТЫ ВОЗДЕЙСТВИЯ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

Объектами воздействия являются компоненты ИСПДн «Бухгалтерия», несанкционированный доступ к которым или воздействие на которые может привести к описанным выше негативным последствиям. Объекты определены на основе архитектуры системы (раздел 2) с учётом иерархии: информационные ресурсы, программные средства, технические средства, сетевые протоколы, персонал.

4.1. Перечень основных объектов воздействия

Таблица 4.1 – Состав объектов воздействия

№	Объект воздействия	Физическое размещение / Принадлежность к системе	Роль в обработке информации
1	База данных ПДн (файлы СУБД, файловая БД 1С)	Сервер приложений / БД (внутри КЗ)	Хранилище всех персональных данных, бухгалтерских проводок, платёжных реквизитов
2	Сервер приложений 1С и серверная ОС	Серверная стойка, кабинет бухгалтерии	Обработка запросов пользователей, выполнение регламентных заданий, управление доступом к БД
3	АРМ бухгалтеров (включая ОС)	Кабинет бухгалтерии	Ввод, изменение, просмотр ПДн, формирование отчётов, работа с «Клиент-Банк», печать документов
4	АРМ администратора безопасности	Кабинет бухгалтерии	Администрирование ОС, СУБД, управление учётными записями, настройка СЗИ
5	Маршрутизатор (МСЭ)	Стойка / кабинет бухгалтерии	Фильтрация трафика, подключение к Интернет, канал для сдачи отчётности и клиент-банка
6	Каналы передачи данных (ЛВС, Интернет)	Кабельная система, каналы связи	Передача ПДн и финансовых документов между

			АРМ, сервером и внешними системами
7	Съёмные машинные носители (USB-флеш)	Подключаются к АРМ	Несанкционированное копирование информации, перенос вредоносного ПО
8	Периферийное оборудование (МФУ, принтер)	Кабинет бухгалтерии	Распечатка и сканирование документов, содержащих ПДн
9	Бумажные носители (распечатанные документы, налоговые карточки)	Сейф в кабинете бухгалтерии	Хранение конфиденциальной информации в физическом виде
10	Резервные копии БД	Внешний жёсткий диск в сейфе	Восстановление системы; потенциальный канал утечки при краже
11	Средства защиты информации (антивирус, встроенные механизмы ОС)	Сервера, АРМ	Обеспечение базовой защиты от ВПО и НСД (объект воздействия для угроз, направленных на отключение СЗИ)

4.2. Виды воздействия на объекты (применительно к нарушителям)

В таблице 4.2 установлено соответствие между негативными последствиями, объектами воздействия и видами возможного воздействия.

Таблица 4.2 – Объекты и виды воздействия угроз безопасности информации

Негативные последствия	Объекты воздействия	Виды воздействия (по Методике)
Утечка ПДн, нарушение конфиденциальности (У1)	База данных ПДн, АРМ бухгалтеров, резервные копии, съёмные носители, каналы связи, бумажные носители	Несанкционированный доступ к БД (SQL-инъекции, подбор паролей); копирование файлов БД на внешний носитель; перехват трафика (прослушивание L2/L3); хищение бумажных носителей
Финансовый ущерб физическому лицу (У1)	База данных ПДн, каналы связи	Кража идентификационных и банковских данных субъекта из базы; перехват данных при передаче в банк
Нарушение законодательства РФ (У2)	База данных ПДн, АРМ, системные файлы (журналы аудита)	Несанкционированное распространение ПДн; модификация или удаление журналов регистрации

		событий, препятствующая расследованию
Хищение денежных средств организации (У2)	Прикладное ПО (1С, Клиент-Банк), АРМ бухгалтеров, каналы связи	Несанкционированная модификация платёжных реквизитов в 1С; подмена данных в электронных платёжных поручениях; атака «человек посередине» на сессию Клиент-Банка
Нарушение штатного режима / простой системы (У2)	Сервер БД, маршрутизатор, каналы связи, АРМ, серверная ОС	DoS-атака на маршрутизатор (переполнение канала); шифрование файлов БД (вирус-вымогатель); нарушение работоспособности серверной ОС (эксплойты, удаление драйверов)
Принятие неправильных решений (У2)	База данных ПДн, прикладное ПО 1С	Несанкционированная модификация бухгалтерских проводок, ставок налогов, сумм начислений заработной платы
Репутационный ущерб / дискредитация работников (У2)	АРМ бухгалтеров, учётные записи, сервер БД	Действия в системе под чужой учётной записью (вход с использованием украденных паролей); рассылка ложных сведений через корпоративную почту
Отключение средств защиты (У2)	Средства защиты информации, учётные записи администраторов	Умышленная остановка или изменение конфигурации антивируса, межсетевого экрана, служб аудита

5. ИСТОЧНИКИ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

5.1. Определение источников угроз безопасности информации (модель нарушителя)

В соответствии с пунктом 5.1 Методики ФСТЭК России от 05.02.2021 под нарушителем понимается физическое лицо (группа лиц), способное реализовать угрозу безопасности информации путём несанкционированного доступа и (или) воздействия на информационные ресурсы и компоненты ИСПДн «Бухгалтерия».

Оценка источников угроз проведена с учётом назначения и архитектуры системы (раздел 2), состава обрабатываемой информации (вторая категория ПДн), уровня защищённости УЗ-3, а также выявленных слабых мест (отсутствие сегментации сети, избыточные права в 1С, использование USB-носителей, прямой доступ в Интернет).

5.1.1. Актуальные виды нарушителей

В таблице 5.1 приведены актуальные виды нарушителей, их категории, уровни возможностей и цели. Классификация выполнена в соответствии с Приложением 6 к Методике.

Таблица 5.1 – Источники угроз безопасности информации ИСПДн «Бухгалтерия»

№	Вид нарушителя	Категория	Уровень возможности	Возможные цели реализации угроз (с привязкой к видам ущерба)	Актуальность
1	Специальные службы иностранных государств	Внешний	Н4	Нанесение ущерба государству (У3)	Неактуально
2	Террористические, экстремистские группировки	Внешний	Н3	Дестабилизация деятельности	Неактуально
3	Преступные группы (криминальные структуры)	Внешний	Н2–Н3	Получение финансовой выгоды: кража и продажа ПДн (У1), хищение денежных средств (У2), вымогательство (У2)	Высокая
4	Отдельные физические лица (хакеры)	Внешний	Н1–Н2	Получение финансовой выгоды, любопытство, самореализация (У1, У2)	Высокая

5	Конкурирующие организации	Внешний	H2	Получение конкурентных преимуществ, кража коммерческой тайны (Y2)	Средняя
6	Разработчики программных, программно-аппаратных средств	Внутренний / Внешний	H3	Внедрение недеklarированных возможностей	Ограниченно актуально
7	Лица, обеспечивающие поставку ПО и оборудования	Внешний	H1–H2	Непреднамеренные ошибки, внедрение закладок	Средняя
8	Лица, привлекаемые для установки, настройки, пусконаладочных и иных работ	Внутренний (в период работ)	H2	Ошибки конфигурации, внесение закладок, получение финансовой выгоды (Y2)	Средняя
9	Лица, обеспечивающие функционирование систем и сетей (администрация, охрана, уборщики)	Внутренний	H1	Непреднамеренные действия, кража носителей (Y1, Y2)	Средняя
10	Авторизованные пользователи систем и сетей (бухгалтеры)	Внутренний	H1	Непреднамеренные ошибки, злоупотребление избыточными правами (Y1, Y2)	Очень высокая
11	Системные администраторы и администраторы безопасности	Внутренний	H2–H3	Злоупотребление привилегиями, месть, сговор с преступными группами (Y1, Y2)	Критическая
12	Бывшие (уволенные) работники	Внешний (после увольнения)	H1–H2	Месть, получение финансовой выгоды (Y1, Y2)	Средняя–высокая
№	Вид нарушителя	Категория	Уровень возможности	Возможные цели реализации угроз	Актуальность

				(с привязкой к видам ущерба)	
--	--	--	--	------------------------------	--

Пояснения к выбору актуальных нарушителей:

1. **Внешние злоумышленники (хакеры, преступные группы)** актуальны из-за наличия прямого подключения системы к сети Интернет, отсутствия должной сегментации сети и слабого межсетевого экрана (отмечено в п. 2.10). Их цели – финансовая выгода (вымогательство с помощью вирусов-шифровальщиков, продажа украденных ПДн) и хищение денежных средств через клиент-банк.
2. **Авторизованные пользователи** – основная группа риска. Отсутствие полноценного разграничения прав внутри 1С, возможность использования USB-носителей и доступ к сети Интернет создают условия как для непреднамеренных ошибок, так и для умышленных действий (кража, подмена реквизитов).
3. **Системные администраторы (и администраторы безопасности)** – обладают максимальными полномочиями, что позволяет им реализовать любую угрозу конфиденциальности, целостности или доступности в одиночку. Мотивация может быть различной (месть, подкуп со стороны преступных групп).
4. **Лица, привлекаемые для работ (подрядчики, «приходящие» сисадмины)** – актуальны в случае отсутствия контроля за их действиями во время настройки оборудования, особенно учитывая возможное совмещение ролей и отсутствие выделенного администратора ИБ.
5. **Конкурирующие организации** – актуальны ограниченно, если бухгалтерия обрабатывает сведения о контрагентах, ценах, условиях договоров, составляющих коммерческую тайну.

Уровни возможностей нарушителей распределены в соответствии с Приложением 8 к Методике:

- **Н1 (базовые)** – сотрудники, технический персонал, бывшие работники. Могут использовать только общедоступные инструменты, действовать в рамках предоставленных прав или через очевидные уязвимости.
- **Н2 (базовые повышенные)** – преступные группы, хакеры, конкуренты, привлекаемые специалисты, системные администраторы. Владеют фреймворками для атак, имеют практические знания о защитных механизмах, могут модифицировать инструменты.

- **НЗ (средние)** – преступные группы с финансированием, продвинутые администраторы. Могут приобретать сведения об уязвимостях, разрабатывать собственные эксплойты, проводить анализ кода.

5.2. Категории актуальных нарушителей

Уточним категорирование для дальнейшего анализа:

- **Внутренние нарушители** – сотрудники бухгалтерии, администраторы, обслуживающий персонал. Они имеют доступ в контролируемую зону и (или) полномочия по доступу к информационным ресурсам. Могут реализовывать как преднамеренные, так и непреднамеренные угрозы.
- **Внешние нарушители** – хакеры, преступные группы, бывшие работники. Не имеют легитимного доступа в КЗ и к ресурсам. Реализуют только преднамеренные угрозы, используя уязвимости периметра, социальную инженерию или неотозванные учётные данные.

Данный перечень нарушителей будет использован для оценки способов реализации угроз (раздел 6) и построения сценариев атак.

6. СПОСОБЫ РЕАЛИЗАЦИИ УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

6.1. Актуальные способы реализации угроз безопасности информации

На основе анализа архитектуры ИСПДн «Бухгалтерия», интерфейсов объектов воздействия и возможностей нарушителей определены актуальные способы реализации угроз (Таблица 6.1). Номера способов реализации (СП) соответствуют Методике ФСТЭК и Банку данных угроз (bdu.fstec.ru).

Таблица 6.1 – Актуальные способы реализации угроз безопасности информации

№ п/п	Вид нарушителя	Категория	Объект воздействия	Доступные интерфейсы	Способы реализации (согласно БДУ ФСТЭК)
1	Преступные группы / Хакеры (Н2–Н3)	Внешний	Маршрутизатор (МСЭ)	Сетевой интерфейс (WAN-порт, внешний IP), Web-интерфейс управления, SSH	СП.1.1 Эксплуатация известных уязвимостей в прошивке маршрутизатора или веб-интерфейсе. СП.2.10 Использование недостатков конфигурации сетевого оборудования (открытые порты, слабые пароли). СП.14.3 Распределённая атака типа «отказ в обслуживании» на внешний канал.
2	Преступные группы / Хакеры (Н2–Н3)	Внешний	Сервер приложений 1С / Сервер БД	Логический интерфейс (порт 1541 – кластер 1С, порт 1433/5432 – СУБД, порт 3389 – RDP)	СП.1.1 Эксплуатация известных уязвимостей в серверной ОС (Windows Server) или СУБД (MS SQL/PostgreSQL). СП.2.1 Использование недостатков проверки вводимых данных (SQL-

					инъекции через веб-сервисы 1С). СП.17.1 Подбор паролей (брутфорс) к учётным записям RDP или администратора 1С.
3	Преступные группы / Хакеры (Н2)	Внешний	АРМ бухгалтеров	Логический интерфейс (электронная почта, веб-браузер)	СП.13.3 Веб-фишинг – создание поддельных страниц входа в 1С или банк-клиент. СП.13.4 Почтовый фишинг – рассылка вредоносных вложений (счета, акты сверки) с макросами. СП.4.3 Внедрение вредоносного ПО через посещение скомпрометированных сайтов (эксплойт-киты).
4	Конкурирующие организации (Н2)	Внешний	АРМ бухгалтеров, каналы связи	Сетевые, логические (HTTP/HTTPS, SMB)	СП.10.1 Атака типа «человек посередине» (MITM) на сессию банк-клиента. СП.7.1 Прослушивание сетевого трафика (сниффинг) в незащищённом сегменте ЛВС (при наличии физического доступа или компрометации узла). СП.9.6 Поиск файлов и каталогов на общих сетевых ресурсах (SMB) для кражи коммерческой информации.
5	Бывшие работники (Н1–Н2)	Внешний (после увольнения)	Сервер 1С, АРМ бухгалтеров	Логический интерфейс (RDP, VPN, клиент 1С)	СП.2.2 Использование неотозванных или слабых учётных данных (паролей бывших

					сотрудников). СП.18.1 Доступ без авторизации через оставленные открытыми сессии удалённого доступа. СП.9.1 Получение данных о пользователях и группах (разведка внутри системы с использованием старых учётных записей).
6	Авторизованные пользователи – бухгалтеры (Н1)	Внутренний	База данных ПДн (1С), съёмные носители (USB)	Пользовательский интерфейс (1С:Предприятие), физический (USB-порт)	СП.18.2 Использование избыточных прав доступа (отсутствие разграничения) для массовой выгрузки ПДн. СП.4.2 Внедрение вредоносного ПО через съёмные носители (личный USB-флеш). СП.2.1 Ошибки ввода данных (непреднамеренное искажение сумм, удаление записей).
7	Авторизованные пользователи – бухгалтеры (Н1)	Внутренний	Прикладное ПО (1С, Клиент-Банк)	Пользовательский интерфейс (1С, браузер)	СП.20.2 Сбор данных перебором веб-страниц (просмотр и копирование ПДн коллег из любопытства). СП.21.3 Искажение данных – ошибочный ввод неверных реквизитов, непреднамеренное изменение ставок налогов.
8	Системные администраторы (Н2–Н3)	Внутренний	Все компоненты ИСПДн (серверы, БД, учётные записи, СЗИ)	Логические (SSH, RDP, консоль управления БД), физические	СП.5.1 Внедрение программных закладок в прикладное ПО или ОС (скрытые учётные записи,

					бэкдоры в 1С). СП.19.4 Удаление или подмена системных файлов ОС, файлов СУБД. СП.24.2 Изменение конфигурации средств защиты (отключение антивируса, журналов аудита). СП.15.1 Шифрование данных (имитация атаки ransomware) с использованием штатных средств.
9	Обслуживающий персонал (охрана, уборщики) (Н1)	Внутренний	Бумажные носители, серверное оборудование, резервные копии	Физический доступ в помещение	СП.24.1 Кража носителей информации (бумажные документы, внешний HDD с резервными копиями). СП.24.3 Физическое уничтожение оборудования или носителей. СП.4.2 Непреднамеренное (или намеренное) подключение заражённого USB-носителя к АРМ для подзарядки.
10	Лица, привлекаемые для работ (подрядчики) (Н2)	Внутренний (в период работ)	Сетевое оборудование, серверы, АРМ	Физический (порты оборудования), логический (консоль управления)	СП.24.2 Внесение изменений в конфигурацию сетевого оборудования (ослабление правил МСЭ, создание скрытых VPN-туннелей). СП.5.1 Установка программных закладок на этапе настройки ПО (недокументированные учётные записи в 1С). СП.2.2 Оставление

					стандартных или «сервисных» паролей без смены.
--	--	--	--	--	--

6.2. Описание интерфейсов объектов воздействия, доступных для использования нарушителями

В таблице 6.2 приведены сводные данные об интерфейсах и соответствующих им способах реализации угроз, доступных различным категориям нарушителей.

Таблица 6.2 – Интерфейсы объектов воздействия и способы реализации угроз

№	Вид нарушителя	Уровень	Категория	Объект воздействия	Доступные интерфейсы	Способы реализации (код по БДУ)	Примеры типовых уязвимостей (по БДУ ФСТЭК)
1	Преступные группы, хакеры	H2–H3	Внешний	Маршрутизатор / МСЭ	Сетевой (WAN), Web, SSH	СП.1.1, СП.2.10, СП.14.3	Уязвимости прошивки сетевого оборудования, недостатки аутентификации и конфигурации (класс СП.2)
2	Преступные группы, хакеры	H2–H3	Внешний	Сервер 1С / БД	Логический (порты 1433, 1541, 3389)	СП.1.1, СП.2.1, СП.17.1	Уязвимости серверной ОС (Windows Server) и СУБД (MS SQL/PostgreSQL), недостатки проверки вводимых данных (класс СП.2), слабые требования к паролям
3	Преступные группы, хакеры	H2	Внешний	АРМ бухгалтеров	Пользовательский (почта, браузер)	СП.13.3, СП.13.4, СП.4.3	Уязвимости клиентского ПО (MS Office, браузеры), социальная инженерия, недостатки проверки

							вводимых данных
4	Конкурирующие организации	H2	Внешний	АРМ бухгалтеров, каналы связи	Сетевые, логические (HTTP/HTTPS, SMB)	СП.10.1, СП.7.1, СП.9.6	Отсутствие шифрования в ЛВС, недостатки конфигурации и сетевых протоколов
5	Бывшие работники	H1–H2	Внешний (после увольнения)	Сервер 1С, АРМ	Логический (RDP, VPN, клиент 1С)	СП.2.2, СП.18.1, СП.9.1	Несвоевременный отзыв учётных записей, оставленные открытыми сессии удалённого доступа
6	Авторизованные пользователи (бухгалтеры)	H1	Внутренний	БД ПДн, USB-носители	Пользовательский (1С), физический (USB)	СП.18.2, СП.4.2	Избыточные права доступа (класс СП.18), отсутствие контроля съёмных носителей
7	Авторизованные пользователи (бухгалтеры)	H1	Внутренний	Прикладное ПО (1С, клиент-банк)	Пользовательский (1С, браузер)	СП.20.2, СП.21.3	Недостатки интерфейса прикладного ПО, отсутствие контроля изменений критичных реквизитов
8	Системные администраторы	H2–H3	Внутренний	Все компоненты (серверы, БД, СЗИ)	Логические (RDP, консоль БД), физические	СП.5.1, СП.19.4, СП.24.2, СП.15.1	Отсутствие сегментированного аудита, возможность изменения конфигурации и СЗИ, архитектурные уязвимости
9	Обслуживающий персонал (охрана, уборщики)	H1	Внутренний	Бумажные носители, резервные копии, сервер	Физический доступ в помещение	СП.24.1, СП.24.3, СП.4.2	Недостатки физической защиты, неопечатанное оборудование

							е, свободные USB-порты
10	Лица, привлекаемые для работ (подрядчик и)	H2	Внутренний (в период работ)	Сетевое оборудование, серверы, АРМ	Физический, логический (консоль)	СП.24.2, СП.5.1, СП.2.2	Ошибки конфигурации, оставление стандартных паролей, установка неавторизованного ПО

7. АКТУАЛЬНЫЕ УГРОЗЫ БЕЗОПАСНОСТИ ИНФОРМАЦИИ

На основе анализа архитектуры ИСПДн «Бухгалтерия», возможных нарушителей и способов реализации угроз сформирован **перечень актуальных угроз безопасности информации** (Таблица 7.1). Для каждой угрозы указаны: идентификатор по Банку данных угроз ФСТЭК, описание применительно к системе, вероятные источники, ключевые объекты воздействия, способы реализации и возможные негативные последствия (У1, У2).

7.1. Перечень актуальных угроз

Таблица 7.1 – Актуальные угрозы безопасности информации ИСПДн «Бухгалтерия»

Код БД У	Угроза безопасности информации	Конкретное проявление в ИСПДн «Бухгалтерия»	Вероятные источники (нарушители)	Объекты воздействия	Способы реализации (коды)	Негативные последствия
УБ И.1	Угроза утечки информации	Несанкционированное копирование персональных данных сотрудников на внешний USB-носитель, передача по электронной почте или выгрузка в облачные сервисы.	Бухгалтеры (Н1), Системные администраторы (Н2–Н3), Внешние хакеры (после взлома) (Н2)	База данных ПДн, АРМ бухгалтеров, резервные копии, каналы связи	СП.18.2, СП.4.2, СП.7.1, СП.9.6	У1 (утечка ПДн, моральный вред), У2 (штрафы Ф3-152, репутационный ущерб)
УБ И.2	Угроза несанкционированного доступа	Получение доступа к серверу 1С или СУБД путём подбора паролей, эксплуатации уязвимостей или использования неотозванных учётных записей.	Внешние хакеры/преступные группы (Н2), Бывшие сотрудники (Н1–Н2), Системные администраторы (Н2)	Сервер приложений 1С, сервер БД, АРМ бухгалтеров	СП.17.1, СП.1.1, СП.2.2, СП.18.1	У1 (доступ к ПДн), У2 (нарушение целостности, хищение данных)
УБ И.3	Угроза несанкционированной модификации (искажения)	Умышленное изменение сумм заработной платы,	Бухгалтеры (Н1), Системные администраторы (Н2–	Прикладное ПО 1С, база данных ПДн,	СП.18.2, СП.21.3, СП.10.	У1 (финансовый ущерб сотруднику), У2

		платёжных реквизитов в «Клиент-Банке» или налоговой отчётности.	Н3), Преступные группы (через удалённый доступ) (Н2)	каналы связи	1, СП.19.4	(хищение средств, штрафы)
УБ И.5	Угроза удаления / шифрования информационных ресурсов	Шифрование баз данных и документов вымогательским ПО (ransomware) с последующим требованием выкупа, либо умышленное уничтожение данных.	Преступные группы (через фишинг) (Н2), Системные администраторы (Н2–Н3), Бухгалтеры (непреднамеренно) (Н1)	Сервер БД, АРМ, резервные копии	СП.13.4, СП.4.3, СП.15.1, СП.24.3	У2 (паралич бухгалтерии, невозможность выплат, потеря данных)
УБ И.6	Угроза отказа в обслуживании	Перегрузка маршрутизатора или канала связи DDoS-атакой, делающая невозможной отправку отчётности и работу с банком.	Внешние преступные группы/хакеры (Н2)	Маршрутизатор, каналы связи	СП.14.3	У2 (срыв сроков платежей и отчётности, финансовые потери)
УБ И.8	Угроза нарушения функционирования (работоспособности)	Непреднамеренная остановка служб, ошибки конфигурации, приводящие к сбоям сервера 1С или СУБД.	Подрядчики (Н2), Системные администраторы (ошибки) (Н1), Обслуживающий персонал (физическое воздействие) (Н1)	Сервер БД, сервер приложений, сетевое оборудование	СП.24.2, СП.2.2, СП.24.3	У2 (простой системы, затраты на восстановление)

7.2. Сценарии реализации угроз безопасности информации (Kill Chain)

Для подтверждения актуальности угроз и возможности их реализации разработаны **сценарии атак**, описывающие последовательность действий нарушителей с использованием способов из таблицы 6.2.

Сценарий 1: Кража персональных данных внутренним нарушителем (бухгалтером) — УБИ.012

Нарушитель: Авторизованный пользователь (бухгалтер), уровень возможностей Н1.

Цель: Получение финансовой выгоды путём продажи базы ПДн.

Ущерб: У1 и У2.

Этап (Тактика по Методике)	Действия нарушителя	Техники MITRE ATT&CK	Инструменты / Интерфейсы
T1. Разведка	Изучение прав доступа и расположения списков сотрудников в 1С. Определение возможности выгрузки данных.	T1592, T1083 (File and Directory Discovery)	Интерфейс 1С (роль «Бухгалтер»)
T2. Подготовка	Создание пользовательского отчёта «Список сотрудников» или «Зарплата ведомость» со всеми ПДн. Сохранение в файл Excel.	T1213 (Data from Information Repositories)	Модуль отчётов 1С
T3. Доставка / Доступ	Подключение личного USB-накопителя к порту АРМ.	T1091 (Replication Through Removable Media)	Физический USB-интерфейс
T4. Исполнение	Копирование файла с ПДн на USB.	T1005 (Data from Local System)	Проводник Windows
T5. Соккрытие следов	Удаление исходного файла отчёта и очистка истории действий в 1С (если доступно).	T1070.004 (File Deletion)	Штатные средства ОС и 1С
T6. Вывод данных	Физический вынос USB за пределы контролируемой зоны.	T1052.001 (Exfiltration over Physical Medium)	USB-носитель
Этап (Тактика по Методике)	Действия нарушителя	Техники MITRE ATT&CK	Инструменты / Интерфейсы

Результат: Массовая утечка ПДн сотрудников. Реализация возможна при отсутствии DLP-системы и контроля USB-портов.

Сценарий 2: Атака шифровальщиком через фишинг (УБИ.5)

Источник: Преступная группа (Н2) – внешний нарушитель.

Цель: Получение выкупа путём шифрования бухгалтерских данных.

Ключевые уязвимости: отсутствие антивируса нового поколения, наличие доступа в Интернет с АРМ, человеческий фактор.

Этап (Тактика)	Действия нарушителя	Техники MITRE ATT&CK	Инструменты / Интерфейсы
T1. Разведка	OSINT-сбор e-mail адресов бухгалтеров (сайт, соцсети).	T1598, T1589	Maltego / Hunter.io
T2. Вооружение	Создание фишингового письма с вредоносным вложением (.docx с макросом или .exe под видом счёта).	T1587.001	Cobalt Strike / Empire
T3. Доставка	Отправка целевого фишинга на адрес бухгалтера.	T1566.001 (Spearphishing Attachment)	Почтовый сервер (SMTP)
T4. Исполнение	Бухгалтер открывает вложение и разрешает выполнение макроса.	T1204.002 (Malicious File)	MS Office, PowerShell
T5. Закрепление	Установка persistence, отключение Defender (по возможности).	T1547.001, T1562.001	PowerShell, реестр
T6. Латеральное перемещение	Распространение по сети через SMB на сервер.	T1021.002 (SMB/Windows Admin Shares)	Эксплойты EternalBlue, PsExec
T7. Воздействие	Шифрование файлов БД 1С и резервных копий (включая внешний HDD).	T1486 (Data Encrypted for Impact)	Шифровальщик (LockBit/Conti)

Результат: Полная парализация работы бухгалтерии, срыв сроков выплат и отчётности, расходы на восстановление.

Сценарий 3: Подмена платёжных реквизитов администратором (УБИ.3)

Источник: Системный администратор (Н2–Н3) – внутренний нарушитель, имеющий сговор с внешней группой.

Цель: Хищение денежных средств организации путём изменения реквизитов в платёжных поручениях.

Ключевые уязвимости: полный доступ администратора к 1С и базе данных, отсутствие контроля целостности реквизитов.

Этап (Тактика)	Действия нарушителя	Техники MITRE ATT&CK	Инструменты / Интерфейсы
T1. Разведка	Изучение расписания платежей, сумм, процедуры подтверждения в Клиент-Банке.	T1592, T1083	Интерфейс 1С, чаты бухгалтерии
T2. Доступ	Вход под привилегированной учётной записью в систему 1С.	T1078 (Valid Accounts)	Клиент 1С
T3. Исполнение	Изменение расчётного счёта контрагента в справочнике.	T1565 (Data Manipulation)	Модуль «Контрагенты»
T4. Скрытие следов	Очистка или модификация журнала регистрации 1С для скрывания факта изменений.	T1070.001 (Clear Logs)	Административные права в 1С
T5. Эффект	Формирование и отправка легитимного платёжного поручения на подставной счёт. Подпись ЭЦП (если доступна или подставлена).	T1485, T1650	Клиент-Банк (HTTPS)
Этап (Тактика)	Действия нарушителя	Техники MITRE ATT&CK	Инструменты / Интерфейсы

Результат: Прямое хищение денежных средств организации.

ВЫВОД ОБ АКТУАЛЬНОСТИ УГРОЗ

Все шесть видов угроз (УБИ.1, УБИ.2, УБИ.3, УБИ.5, УБИ.6, УБИ.8) признаются **актуальными** для ИСПДн «Бухгалтерия», так как:

- Существуют конкретные нарушители (внешние и внутренние) с достаточным уровнем возможностей.
- Имеются необходимые интерфейсы и слабые места архитектуры (прямой выход в Интернет, избыточные права, использование USB, отсутствие сегментации).
- Разработаны реализуемые сценарии атак (три приведённых сценария демонстрируют практическую возможность реализации угроз).
- Реализация любой из перечисленных угроз приведёт к значительным негативным последствиям – как для субъектов ПДн (У1), так и для организации-оператора (У2).

Данный перечень угроз служит основанием для проектирования системы защиты персональных данных и выбора соответствующих организационных и технических мер защиты информации.